

Authorization and RBAC

Module 5 - Lesson 3

Overview

Authorization decides what an authenticated user may do. Role-based access control (RBAC) groups permissions into roles so you can grant and revoke access simply.

Key Concepts

- Authentication proves identity; authorization grants capability.
- RBAC models roles (student, instructor, admin) and assigns permissions to roles.
- Middleware or route guards check authorization before running the handler.
- Enforce checks on the server, never trust client-side flags.
- Check ownership (is this the resource owner?) in addition to roles.
- Fail closed: deny by default and allow explicitly.

Example

```
if (req.user.role !== 'admin' && req.user.id !== course.instructorId) {  
  return res.status(403).json({ error: 'Forbidden' });  
}  
// only owners and admins may edit this course
```

Summary

Authorization with RBAC keeps roles and permissions explicit. Enforce checks server-side, verify ownership, and fail closed to keep protected resources safe.

Practice Checklist

- Add a student and instructor role with different allowed endpoints.
- Protect a route so only the resource owner can edit it.
- Write a test that confirms a forbidden request returns 403.